

Tabletop Exercise

Business Email Compromise and Wire Fraud

Executive Impersonation and Fraudulent Wire Transfer

Exercise package

Facilitation-ready scenario with phased injects, expected actions, decision points, debrief material, and expanded MITRE ATT&CK mapping. Revised to address evaluation feedback on cyber lifecycle accuracy.

Classification	Internal use only
Scenario type	Business Email Compromise (BEC) / Payment Fraud
Primary audience	Executive, operational, treasury, fraud, legal, compliance, communications, and technical response stakeholders
Recommended duration	60-90 minutes
Format	Facilitated discussion-based tabletop with phased injects and debriefs
Prepared version	Revised exercise design - July 2026

Document control note: This document is designed for exercise planning and facilitation. It should be adapted to the organization's approved incident response, fraud recovery, crisis management, legal, and regulatory procedures before live use.

Table of Contents

1. Exercise Overview	4
2. Purpose	4
3. Exercise Objectives	4
Role-specific learning outcomes	5
4. Suggested Participants	5
Executive / strategic participants	5
Operational participants	5
Technical / control participants	5
Exercise control roles	5
5. Scope	6
6. Assumptions	6
7. Rules of Engagement	6
8. Scenario Summary	6
Key scenario tensions	6
9. Threat Context	7
Threat actor profile	7
Attack pattern	7
Primary business risk	7
Plausible indicators	7
10. Exercise Timeline and Injects	7
Phase 1 - Suspicious Executive Request	8
Phase 2 - Pressure, Exception Path, and Transfer Release	8
Phase 3 - Containment, Investigation, and Wider Exposure Assessment	9
Phase 4 - Outcome, Recovery, and Reporting	10
11. Decision Points	11
12. Operational and Business Impacts	11

13. Facilitator Guide	12
Suggested flow	12
Facilitation tips	12
Evidence prompts	12
Facilitator inject control	12
14. Evaluation Criteria	13
15. Debrief Questions	13
16. Recommended Improvement Actions	13
Immediate	13
Near term	13
Longer term	14
17. MITRE ATT&CK; Mapping	14
17.1 Core and conditional ATT&CK; mapping	15
17.2 Techniques deliberately not asserted in the baseline	16
17.3 ATT&CK; use during facilitation	16
17.4 Reference techniques used for mapping	16
18. Optional Variant Paths	16
19. Closing	16

1. Exercise Overview

Field	Details
Title	Executive Impersonation and Fraudulent Wire Transfer
Scenario Type	Business Email Compromise (BEC) / Payment Fraud
Audience	Executive, operational, treasury, fraud, legal, compliance, communications, and technical response stakeholders
Duration	60-90 minutes
Format	Facilitated tabletop exercise with phased injects, decision points, expected actions, and debriefs
Classification	Internal use only
Revision focus	Expanded cyber lifecycle mapping and clearer investigative branching between spoofing, look-alike domain abuse, and confirmed mailbox compromise.

Design improvement integrated

The exercise retains the original banking BEC narrative while strengthening the technical accuracy of the MITRE ATT&CK section. The revised mapping distinguishes the baseline social-engineering fraud from optional mailbox-compromise evidence, rather than forcing malware, execution, or command-and-control techniques that are not present.

2. Purpose

This tabletop exercise tests the organization's ability to identify, contain, escalate, and respond to a business email compromise attempt involving executive impersonation and an urgent overseas wire transfer request. The exercise focuses on fraud controls, crisis decision-making, communications, evidence preservation, post-transfer recovery actions, and cyber/fraud coordination.

The scenario is intentionally business-process centered: the adversary's primary objective is not malware deployment, but manipulation of trust, urgency, payment exception handling, and transaction workflow integrity.

3. Exercise Objectives

By the end of the exercise, participants should be able to:

- Validate controls for urgent, confidential, cross-border, high-value, and beneficiary-change payment requests.
- Assess whether out-of-band verification, dual authorization, and exception-path procedures are understood and consistently applied.
- Test escalation between Treasury, Finance, Fraud, Security, Legal, Compliance, Communications, Business Continuity, and Executive leadership.
- Evaluate the organization's ability to respond once a fraudulent transfer has been released, including immediate recall and counterparty coordination.
- Review evidence preservation across email, identity, messaging, payment approval, call, and audit-log sources.
- Distinguish between a spoofed BEC message, look-alike domain abuse, and confirmed mailbox compromise.
- Clarify regulatory, law-enforcement, insurer, client, and counterparty notification decision thresholds.
- Identify gaps in playbooks, training, crisis governance, technical monitoring, and executive communications.

Role-specific learning outcomes

Audience	Expected learning outcome
Executive / crisis leadership	Make time-sensitive decisions with incomplete facts; balance financial loss, recovery speed, legal privilege, reporting obligations, and reputational risk.
Treasury / payment operations	Apply verification controls, resist exception pressure, preserve approval evidence, and initiate immediate fraud recovery procedures.
Fraud / investigations	Coordinate recall, beneficiary-bank engagement, correspondent-bank tracing, suspicious transaction review, and law-enforcement package preparation.
Security / technical teams	Triage email and identity artifacts, scope similar messages, validate mailbox compromise indicators, and provide evidence-backed risk statements.
Legal / compliance / communications	Determine notification thresholds, preserve privilege where appropriate, approve internal/external messaging, and ensure records support post-incident reporting.

4. Suggested Participants

Executive / strategic participants

- CFO or delegate
- COO or business leadership representative
- Crisis management lead
- Corporate communications lead
- Legal counsel
- Compliance / regulatory affairs lead
- Operational risk representative

Operational participants

- Treasury operations manager
- Payment operations lead
- Fraud investigations lead
- Relationship / correspondent banking representative
- Client service or business-line representative
- Business continuity lead

Technical / control participants

- Security operations / incident response lead
- Email security / messaging administrator
- Identity and access management representative
- Threat intelligence representative
- Insider risk / monitoring representative
- Records / forensic preservation representative

Exercise control roles

- Lead facilitator: manages scenario pacing, injects, and discussion discipline.
- Observer / evaluator: records decisions, gaps, dependencies, and time-to-action.
- Scribe: captures decisions, actions, owners, open questions, and post-exercise improvement items.

5. Scope

In scope	Out of scope
Executive impersonation by email; payment approval workflow and exception handling; fraud detection and transaction recall process; internal escalation and crisis coordination; external notifications to correspondent / beneficiary institutions; evidence preservation; executive, legal, regulatory, and communications decision-making; mailbox-compromise triage if Variant A is used.	Detailed malware reverse engineering; exploit development; deep endpoint forensics beyond triage; physical security response; unrelated infrastructure recovery; live testing of production payment systems; actual outreach to external institutions during the exercise.

6. Assumptions

- The organization is a commercial bank with established treasury and high-value payment approval processes.
- High-value and urgent transfer requests require dual authorization and, in some cases, additional verbal or authenticated verification.
- Email is widely used for executive-to-operations communication, but email alone is not sufficient approval for new beneficiary or high-risk payment changes.
- The institution has access to legal, fraud, security, and executive escalation channels.
- The scenario is discussion-based. Participants should respond according to existing roles, authorities, and procedures.
- The facilitator may adjust the transfer value, jurisdiction, beneficiary country, or regulatory expectations to match the audience.
- No actual customer funds, production systems, or third-party contacts are used during the exercise.

7. Rules of Engagement

- This is a no-fault learning exercise.
- Participants should answer from their real role and current process.
- There are no perfect answers; the goal is to identify strengths, gaps, dependencies, and decision points.
- Facilitators may introduce new facts as the scenario evolves.
- Real-world incidents take precedence over the exercise.
- Participants should distinguish confirmed facts from assumptions and record both.
- Sensitive control gaps discussed during the exercise should be handled according to internal confidentiality and remediation processes.

8. Scenario Summary

A financially motivated threat actor conducts a targeted business email compromise campaign against the bank's payment approval process. A senior finance or treasury-adjacent employee receives an email that appears to come from the CFO. The message references a confidential acquisition closing and instructs the recipient to urgently release a large overseas wire transfer to a newly provided beneficiary account. The tone emphasizes secrecy, timing, and executive authority.

Under pressure and with limited ability to verify the request through normal channels, the transaction proceeds through an exception path. Shortly after release, the CFO denies sending the email. The organization must decide how to contain damage, initiate recall, preserve evidence, scope potential mailbox compromise, notify relevant parties, and brief leadership while balancing legal, regulatory, client, and reputational considerations.

Key scenario tensions

- Speed versus certainty: recall and counterparty contact may need to begin before full forensic confirmation.
- Authority versus control: senior-executive pressure may conflict with established verification procedures.
- Fraud versus cyber ownership: payment fraud and email-security investigation must operate as one coordinated incident.

- Secrecy versus escalation: confidentiality claims should not override mandatory controls and escalation thresholds.
- Single event versus campaign: one fraudulent wire request may be part of broader targeting of finance approvers.

9. Threat Context

Threat actor profile

The actor is financially motivated and uses social engineering, executive impersonation, and payment-process manipulation to induce fraudulent wire approval. The actor may operate through spoofed email, a look-alike domain, a deceptive reply-to address, a free webmail account, or - in the optional technical branch - a compromised mailbox in the executive support chain.

Attack pattern

- Researches executive roles, treasury operations, payment approval chains, and transaction timing.
- Creates a plausible urgent business pretext, such as a confidential acquisition closing or settlement deadline.
- Impersonates an executive and discourages normal verification by emphasizing secrecy and time pressure.
- Introduces a new or changed beneficiary account and pressures staff to use an exception path.
- Relies on delays in escalation, fragmented cyber/fraud workflows, and uncertainty over ownership.
- May attempt mailbox access, forwarding rules, or hiding rules if the facilitator activates Variant A.

Primary business risk

The primary business risk is financial loss from an unauthorized transfer, followed by reputational harm, regulatory scrutiny, legal exposure, disruption to treasury operations, and reduced confidence in executive communications and payment controls.

Plausible indicators

- Urgent payment instruction tied to confidential activity.
- New beneficiary, unusual geography, unusual value, or unusual timing.
- Sender display name matches an executive, but headers, reply-to, return-path, domain age, or SPF/DKIM/DMARC results appear suspicious.
- Requester discourages callback, ticketing, written confirmation, or ordinary approval workflow.
- Similar subject line or wording appears in messages sent to other finance or treasury staff.
- Mailbox audit data shows unusual sign-in, forwarding, inbox rule, delegate permission, or session activity (Variant A only).

10. Exercise Timeline and Injects

Phase	Time	Inject focus	Primary decisions
1	09:15	Suspicious executive request received	Pause payment, verify out-of-band, preserve evidence, escalate appropriately.
2	10:05	Payment released through pressured exception path; CFO denies request	Activate cyber/fraud incident, initiate recall, contact institutions, brief leadership.
3	13:30	Investigation indicates spoofing/look-alike source; mailbox compromise cannot be ruled out	Scope campaign, validate identity artifacts, impose temporary controls, decide notification posture.
4	Next business day	Recovery outcome uncertain or partial; reporting and remediation decisions required	Assess impact, notifications, communications, post-incident reporting, and control changes.

Phase 1 - Suspicious Executive Request

Inject 1

A senior manager in treasury operations receives an email appearing to come from the CFO. The message states that a confidential acquisition closing is occurring today and instructs the manager to immediately release a high-value overseas wire transfer to a newly provided beneficiary. The message emphasizes that timing is critical, the matter is highly confidential, and normal communication channels may delay the closing.

What participants know at this stage

- The email appears legitimate at first glance.
- The sender display name matches the CFO.
- The transfer is large, cross-border, time-sensitive, and outside the normal beneficiary pattern.
- The beneficiary account is unfamiliar or newly introduced.
- The request discourages ordinary verification and suggests confidentiality as a reason not to escalate.
- No payment has been released yet.

Discussion questions

- What immediate actions should the recipient take before any approval occurs?
- Which payment controls are triggered by value, urgency, geography, beneficiary change, and confidentiality claims?
- Is the request sufficient to justify pausing payment execution?
- What out-of-band verification methods are mandatory and who is authorized to perform them?
- Who should be informed internally at this stage - Treasury leadership, Fraud, Security, Legal, or the CFO's office?
- What evidence should be preserved immediately, even if the payment is stopped?

Expected actions

- Halt or place the payment in review pending verification.
- Validate the request using an approved out-of-band channel, not by replying to the suspicious email.
- Check sender domain, reply-to, return-path, authentication results, routing, and header artifacts for suspicious indicators.
- Escalate to Treasury leadership, Fraud, and Security as appropriate.
- Preserve the email, headers, approval trail, related chats, call notes, and any attempted callback evidence.
- Record why the request met fraud/cyber escalation criteria.

Facilitator notes

Prompt discussion on practical friction points: executive pressure, after-hours approvals, confidential transactions, unavailable approvers, whether exception handling is too permissive, and whether staff feel empowered to challenge an executive request.

Phase 2 - Pressure, Exception Path, and Transfer Release

Inject 2

The payment is released after a pressured approval path. A participant learns shortly afterward that the CFO denies sending the email. The organization must now decide how to initiate a fraud recall, preserve evidence, notify counterpart institutions, and brief executives. Time is critical because the transfer may soon move through additional accounts.

What participants know at this stage

- The wire has been released.
- The CFO states the message is fraudulent.
- The beneficiary account is outside the bank's normal payment pattern.
- Internal concern rises that this was a BEC-driven wire fraud event.
- The recovery window is narrowing.
- It is not yet known whether the email was spoofed, sent from a look-alike domain, or involved a compromised mailbox.

Discussion questions

- Who owns incident command now: Treasury, Fraud, Security, Crisis Management, or a joint structure?
- What are the first 15-30 minute actions to maximize the chance of fund recovery?
- Which external institutions must be contacted and in what order?
- When should legal counsel be engaged and what should be treated as privileged investigation work product?
- What evidence must be preserved to support investigation, recovery, insurance, and potential law-enforcement reporting?
- What thresholds trigger executive notification and crisis governance activation?
- How will the bank manage internal communications while facts are still developing?

Expected actions

- Initiate fraud recall or financial institution recovery procedures immediately.
- Contact beneficiary bank and any correspondent / intermediary institutions through approved recovery channels.
- Open a combined cyber/fraud incident and establish a single command structure with clear decision authority.
- Preserve payment records, email records, identity logs, approvals, beneficiary details, call records, and user communications.
- Notify executive leadership with a concise fact/assumption/risk summary.
- Assess whether related accounts, mailboxes, or payment workflows may also be targeted.
- Begin enhanced scrutiny of urgent wires, new beneficiaries, and exception approvals while the investigation proceeds.

Facilitator notes

Push participants on speed versus certainty. Recovery decisions often must be made before complete forensic confirmation. Explore whether the institution has a single coordinated playbook or fragmented fraud and cyber procedures.

Phase 3 - Containment, Investigation, and Wider Exposure Assessment

Inject 3

Initial review indicates the email likely originated from a spoofed or deceptive source rather than the CFO's legitimate mailbox, but investigators cannot yet rule out mailbox compromise elsewhere in the executive support chain. Similar lure language may have been sent to other finance approvers. The bank must determine whether this was a standalone social engineering attempt or part of a broader campaign targeting payment workflows.

What participants know at this stage

- The event may be display-name spoofing, a look-alike domain, deceptive reply-to abuse, unauthorized use of a related mailbox, or a combination of these.
- Similar messages may have reached other finance approvers.
- There is no confirmed endpoint compromise at this time.
- There is no confirmed customer data exposure at this time.
- Media, clients, and regulators are not yet aware.
- The organization must avoid declaring the event 'contained' before message trace, identity, and payment workflow scoping are complete.

Discussion questions

- What scoping actions should Security take now?
- Do you search for similar messages across the environment, including deleted/quarantined mail and forwarded copies?
- Should enhanced monitoring or temporary payment restrictions be applied?
- What is the threshold for treating this as an enterprise campaign rather than a single fraud case?
- What technical evidence would prove or disprove mailbox compromise?
- Who decides whether clients, partners, auditors, insurers, law enforcement, or regulators are notified?

Expected actions

- Search the environment for similar emails, subjects, domains, sender IPs, reply-to values, URLs, and recipient patterns.

- Review executive and executive-support mailbox activity: successful sign-ins, MFA events, token activity, OAuth grants, inbox rules, forwarding, delegate permissions, and impossible-travel indicators.
- Block confirmed malicious domains/senders and remove or quarantine related messages where appropriate.
- Increase scrutiny over urgent wires, beneficiary changes, callback exceptions, and manually approved payments.
- Coordinate communications and legal review before any external statements.
- Document decisions, timelines, authorities, evidence handling, and rejected hypotheses.

Investigation branch for facilitator

Branch	Evidence presented	Facilitation purpose
Baseline path	Headers show a look-alike or spoofed source; CFO mailbox audit logs show no suspicious access.	Tests process-control failure, fraud recovery, and scoping without adding unproven technical compromise.
Variant A - mailbox compromise	Investigators find remote access to a CFO support mailbox, a new forwarding rule, and an inbox rule hiding replies or alerts.	Adds identity containment, mailbox forensics, persistence/defense evasion mapping, and broader notification analysis.
Variant B - multiple targets	Similar messages were sent to three finance approvers using the same pretext and beneficiary details.	Tests enterprise campaign response and mass-notification procedures.
Variant C - partial recovery	Funds were partially frozen, but a portion moved onward before a full hold was placed.	Tests executive impact assessment, legal posture, and communications under financial-loss uncertainty.

Facilitator notes

Use this phase to test cross-functional coordination between cyber, fraud, treasury, legal, and communications. If participants focus only on the single wire, prompt them to consider systemic exposure and whether preventive controls should be temporarily tightened.

Phase 4 - Outcome, Recovery, and Reporting

Inject 4

The bank receives partial feedback from external institutions: either the transfer is frozen in time, partially recovered, or moved onward before a full hold was placed. Leadership requests a decision on communications, regulatory notification, customer impact assessment, insurance engagement, law-enforcement coordination, and post-incident remediation.

What participants know at this stage

- Recovery outcome is uncertain or partial.
- Control weaknesses and exception-handling gaps are now visible.
- Executive leadership wants a clear impact statement and next-step plan.
- Regulators, law enforcement, insurers, auditors, customers, or counterparties may need to be engaged depending on jurisdiction, impact, and policy.
- Short-term controls may disrupt treasury operations but reduce further fraud risk.

Discussion questions

- How is business impact assessed and communicated to leadership?
- What legal and regulatory obligations apply, and who makes the final determination?
- How is reputational risk managed if the event becomes public?
- What immediate control changes should be made before business-as-usual resumes?
- What should go into the post-incident report and lessons-learned review?
- What evidence is needed to support recovery, disciplinary action, insurance, or law-enforcement engagement?
- What should be communicated to staff about verifying urgent executive requests?

Expected actions

- Confirm financial exposure and recovery status using documented sources.
- Determine reporting obligations with Legal and Compliance.
- Brief executives using clear facts, assumptions, decisions, owners, open risks, and next steps.

- Implement short-term control enhancements for payment approvals, callback verification, new beneficiaries, and executive requests.
- Finalize evidence preservation and chain-of-custody expectations.
- Launch post-incident review and lessons-learned process with named owners and deadlines.

Facilitator notes

Allow the group to discuss multiple possible endings: successful recall, partial loss, full loss, or discovery of wider targeting. This helps test resilience across different outcomes.

11. Decision Points

Key decision points for the facilitator to emphasize:

- Whether to halt payment pending secondary verification.
- Whether confidentiality claims change or reinforce required controls.
- Whether the request qualifies as a fraud event, cyber event, or combined incident.
- Who has authority to activate crisis management and who leads the incident command structure.
- When to initiate recall before full validation is complete.
- Whether to impose temporary enhanced controls on similar payments.
- Whether to disable or restrict implicated accounts, sessions, rules, and forwarding configurations.
- Whether and when regulatory, law-enforcement, insurer, auditor, customer, or counterparty notification thresholds are met.
- What executive message is delivered internally and externally.
- What evidence is sufficient to declare the event contained.

12. Operational and Business Impacts

Impact area	Potential impacts	Facilitator prompts
Operational	Disruption to high-value payment approvals; increased manual review; delays to treasury operations; emergency coordination across multiple teams.	Which payments are time-critical? Who approves temporary restrictions? How are exceptions documented?
Financial	Direct loss, partial recovery uncertainty, liquidity impact, correspondent fees, investigation costs, legal costs, and potential insurance deductible considerations.	How do you calculate exposure? Who owns the financial impact statement?
Regulatory / legal	Regulatory scrutiny over payment controls; breach/fraud reporting analysis; privilege considerations; law-enforcement coordination; litigation exposure.	Who decides reportability? What evidence must be preserved?
Reputational	Reduced confidence in executive communications, client concern, media attention, and counterparty trust issues.	Who approves talking points? What can be said while facts are incomplete?
Technical / control	Email security tuning, mailbox and identity scoping, fraud-control analytics, temporary payment workflow controls, and alert triage load.	Which technical controls would have detected this earlier? Which gaps require immediate remediation?

13. Facilitator Guide

Suggested flow

Segment	Duration	Facilitator objective
Introduction, objectives, rules	10 min	Confirm scope, no-fault framing, roles, and decision-recording approach.
Phase 1 discussion	10 min	Test prevention: recognition, verification, and stop-payment authority.
Phase 2 discussion	15 min	Test response speed: recall, command structure, preservation, and escalation.
Phase 3 discussion	15 min	Test investigation: spoofing versus mailbox compromise, campaign scoping, and temporary controls.
Phase 4 discussion	10 min	Test reporting, communications, impact assessment, and remediation decisions.
Debrief and lessons learned	10-15 min	Capture strengths, gaps, owners, and timelines.

Facilitation tips

- Encourage role-based answers grounded in actual process.
- Ask who has authority, not just who has awareness.
- Challenge assumptions around urgency, executive privilege, confidentiality, and informal workarounds.
- Track where decisions depend on undocumented tribal knowledge.
- Separate what exists on paper from what would happen in practice.
- Ask participants to explicitly identify confirmed facts, working assumptions, and decisions still pending.
- Do not over-technicalize the baseline BEC path; introduce technical depth only when evidence supports it.

Evidence prompts

Ask participants whether they would know how to quickly access and preserve:

- Original email with full headers and message trace data.
- SPF, DKIM, DMARC, return-path, reply-to, and received-path artifacts.
- Payment system audit logs and approval workflow records.
- Callback records, call recordings, meeting notes, and voice-verification logs.
- User activity logs, mailbox audit logs, sign-in logs, MFA events, and session/token data.
- Inbox rules, forwarding rules, delegate permissions, OAuth consent grants, and mobile device associations.
- Beneficiary maintenance history, correspondent bank messages, recall requests, and recovery correspondence.
- Internal incident notes, legal hold instructions, decision logs, and communications drafts.

Facilitator inject control

- Use the baseline path if the goal is payment-control governance and fraud response.
- Use Variant A if the goal is to test identity, mailbox, and SaaS control response in addition to payment fraud.
- Use Variant C if the goal is executive impact management and communications under financial-loss uncertainty.
- Keep technical findings evidence-based. Do not declare mailbox compromise unless logs, rules, or access artifacts support it.

14. Evaluation Criteria

Capability area	Strong performance indicators
Recognition of BEC indicators	Participants identify urgency, confidentiality, executive impersonation, new beneficiary, unusual geography/value, and discouragement of verification.
Payment verification controls	Participants stop or hold payment until mandatory out-of-band verification and dual authorization are satisfied.
Escalation timeliness	Fraud, Security, Legal, Treasury leadership, and executives are engaged quickly through known channels.
Incident command	A single cyber/fraud command structure is established with clear decision rights and documentation.
Fraud recall and recovery	Recall and counterparty contact begin immediately using approved procedures, with evidence preserved.
Technical scoping	Security distinguishes spoofing, look-alike domain, and mailbox compromise; searches for related messages and identity artifacts.
Evidence preservation	Email, logs, payment approvals, beneficiary details, calls, and communications are retained with a clear chain of custody where needed.
Legal/regulatory awareness	Legal and Compliance determine notifications using documented criteria and current jurisdictional requirements.
Communications quality	Internal and external messages are accurate, timely, approved, and clear about known facts versus assumptions.
Lessons learned	Control gaps are converted into prioritized actions with accountable owners and due dates.

15. Debrief Questions

- What worked well in the first 30 minutes of the scenario?
- Where did process ambiguity or role confusion emerge?
- Were fraud and cyber workflows integrated or siloed?
- Could the current process withstand a sophisticated executive impersonation attempt?
- Are exception paths too easy to invoke under pressure?
- How effective are current out-of-band verification controls?
- Would staff feel empowered to challenge an urgent executive request?
- Could Security rapidly distinguish spoofing, look-alike domain abuse, and mailbox compromise?
- Could the organization rapidly determine whether other finance personnel were targeted?
- What immediate procedural or technical changes are needed?
- What long-term control, training, or governance improvements should be prioritized?

16. Recommended Improvement Actions

Immediate

- Reiterate mandatory out-of-band verification for urgent, confidential, high-value, cross-border, and beneficiary-change transfer requests.
- Require enhanced review for new or changed beneficiaries and unusual payment patterns.
- Tune email controls for executive impersonation, look-alike domains, deceptive reply-to values, and display-name abuse.
- Create a single cyber/fraud rapid response checklist for payment fraud events.
- Confirm recall contact lists, correspondent-bank channels, and internal escalation trees are current.
- Define when Treasury can halt a payment even under executive pressure.

Near term

- Test callback procedures and approval authority verification.
- Review exception handling governance and approval evidence retention.
- Strengthen treasury fraud scenarios in training and awareness programs.

- Establish clearer criteria for crisis activation and external notification.
- Create an evidence preservation checklist for BEC and payment fraud.
- Add specific detection and investigation procedures for inbox rules, forwarding, delegate permissions, MFA anomalies, and OAuth grants.

Longer term

- Mature anti-spoofing protections, email authentication enforcement, and executive communication safeguards.
- Improve transaction analytics for anomalous urgency, geography, value, beneficiary changes, and exception approvals.
- Integrate fraud, cyber, legal, and communications playbooks into a common incident command model.
- Run additional exercises involving confirmed mailbox compromise, account takeover, multi-stage BEC, partial recovery, and media inquiry.
- Review metrics: time to halt, time to recall, time to executive notification, time to evidence preservation, and time to campaign scoping.

17. MITRE ATT&CK Mapping

Mapping approach

This scenario is primarily a social engineering and business-process compromise exercise. The baseline path does not include malware execution, endpoint compromise, or command-and-control. The mapping below therefore separates baseline techniques from conditional techniques that apply only if the facilitator introduces look-alike infrastructure or confirmed mailbox compromise.

17.1 Core and conditional ATT&CK mapping

Scenario condition	Tactic	Technique ID / name	How it appears in the exercise	Evidence to confirm
Baseline / targeted pretext	Reconnaissance	T1591 - Gather Victim Org Information	The lure references executive roles, finance authority, transaction timing, and a plausible confidential closing. Use this as an inferred pre-attack step only if the facilitator states the actor researched the organization.	Open-source references, lure specificity, targeting of approvers, prior reconnaissance indicators.
Conditional - look-alike domain	Resource Development	T1583.001 - Acquire Infrastructure: Domains	If the email comes from a look-alike domain, the actor likely acquired or controlled a domain for targeting.	Domain registration, DNS records, email gateway logs, domain age, sender infrastructure.
Conditional - free/deceptive email account	Resource Development	T1585.002 - Establish Accounts: Email Accounts	If the lure is sent from a webmail or newly created persona account, the actor established email accounts to support targeting.	Sender account artifacts, mail provider headers, account naming pattern.
Baseline	Initial Access	T1566 - Phishing	The actor sends a deceptive email posing as the CFO to induce action by the recipient. This is the main ATT&CK mapping for the baseline BEC path.	Original message, headers, message trace, recipient list, email-security verdicts.
Conditional - actual mailbox access	Initial Access / Persistence / Defense Evasion	T1078.004 - Valid Accounts: Cloud Accounts	If the CFO or executive-support mailbox was accessed using valid cloud credentials, the actor used a valid account rather than only spoofing.	Sign-in logs, MFA prompts, token activity, device/IP anomalies, session revocation evidence.
Variant A - mailbox compromise	Collection	T1114.002 - Email Collection: Remote Email Collection	If the actor remotely accessed Exchange, Microsoft 365, Google Workspace, or another mail platform to read sensitive mail, this maps to remote email collection.	Mailbox audit logs, search/read events, anomalous mailbox sessions, eDiscovery/audit records.
Variant A - forwarding rule	Collection	T1114.003 - Email Collection: Email Forwarding Rule	If investigators discover a new forwarding rule in the CFO or support mailbox, this maps more precisely than T1114.002 for auto-forwarding behavior.	New-InboxRule/Set-InboxRule events, forwarding SMTP address, unified audit logs, transport rules.
Variant A - delegate persistence	Persistence / Privilege Escalation	T1098.002 - Account Manipulation: Additional Email Delegate Permissions	If the actor grants mailbox permissions or delegate access to maintain mailbox visibility, this maps to account manipulation.	Mailbox permission changes, delegate settings, admin audit logs, anomalous permission assignments.
Variant A - hidden email activity	Defense Evasion	T1564.008 - Hide Artifacts: Email Hiding Rules	If inbox rules move, mark read, delete, or hide replies, alerts, or verification messages, this maps to email hiding rules.	Rule changes, deleted/moved message patterns, alert suppression, mailbox audit events.
Baseline / payment workflow	Impact	T1565.002 - Data Manipulation: Transmitted Data Manipulation	The fraudulent instruction manipulates transmitted payment/beneficiary data in a business workflow, causing funds to be routed to an unauthorized beneficiary. Use this as the primary Impact mapping for the fraudulent-transfer outcome.	Payment instruction trail, beneficiary change, approval records, payment messages, recall documentation.
Supplemental only	Initial Access	T1199 - Trusted Relationship	Use only if the scenario is extended so the actor leverages a compromised trusted third party, external advisor, vendor, or delegated partner account. Do not use as the main mapping for simple executive display-name impersonation.	Evidence of third-party account compromise or abuse of trusted external access.

17.2 Techniques deliberately not asserted in the baseline

Tactic / area	Baseline mapping decision	Rationale
Execution	Not mapped	No malware, scripts, macros, malicious attachments, or endpoint execution are established in the baseline scenario.
Persistence	Not mapped in baseline; mapped in Variant A if mailbox rules, valid accounts, or delegate permissions are confirmed.	A pure spoofed-email BEC does not prove persistent access. Persistence requires specific evidence.
Command and Control	Not mapped	The baseline does not establish an interactive session or C2 channel.
Exfiltration	Not mapped in baseline	No customer or enterprise data exfiltration is confirmed. Email collection may be mapped only in Variant A.
Malware / endpoint compromise	Out of scope	The exercise intentionally focuses on payment-process compromise and email/identity triage.

17.3 ATT&CK use during facilitation

- Ask participants which techniques are evidenced, which are hypotheses, and which should be ruled out.
- Require evidence before escalating from spoofing to mailbox compromise.
- Use the mapping to drive log-source discussion: message trace, identity provider, mailbox audit, payment audit, and SIEM data.
- Emphasize that not every BEC event has a complete intrusion lifecycle; forcing unsupported techniques reduces cyber accuracy.

17.4 Reference techniques used for mapping

MITRE ATT&CK Enterprise techniques referenced in this exercise: T1591, T1583.001, T1585.002, T1566, T1078.004, T1114.002, T1114.003, T1098.002, T1564.008, T1565.002, and T1199. Facilitators should validate technique names against the live ATT&CK knowledge base when adapting the exercise.

18. Optional Variant Paths

Variant	Inject change	Training value	Additional ATT&CK mapping
Variant A - Mailbox compromise confirmed	Investigators discover the CFO support mailbox had a suspicious sign-in, a forwarding rule, and an inbox rule hiding replies.	Tests identity containment, mailbox forensics, token/session revocation, forwarding cleanup, and broader notification analysis.	T1078.004, T1114.002, T1114.003, T1098.002, T1564.008
Variant B - Multiple targets	Similar messages were sent to several finance and treasury approvers.	Tests campaign scoping, enterprise search, staff warning, and temporary payment restrictions.	T1566; possibly T1591 if targeting shows pre-attack research.
Variant C - Partial recovery only	Funds moved through additional accounts before recall landed; only part of the amount is frozen.	Tests executive reporting, legal strategy, insurance, and law-enforcement coordination.	T1565.002
Variant D - Media inquiry	A journalist contacts Communications asking whether the bank lost funds to executive impersonation fraud.	Tests approved messaging, fact discipline, legal review, and reputational risk management.	No additional technique unless new evidence is introduced.
Variant E - Client impact question	A large corporate client asks whether their payments or data were affected.	Tests client impact assessment, business-line coordination, and notification discipline.	No additional technique unless mailbox/data access is confirmed.

19. Closing

This exercise helps participants rehearse a realistic, high-pressure fraud scenario at the intersection of cyber security, operational risk, treasury controls, legal response, and executive decision-making. The quality of the response depends less on technical complexity than on disciplined verification, rapid escalation, coordinated recall action, evidence preservation, and willingness to challenge urgency when normal controls are being bypassed.

The revised ATT&CK section improves cyber accuracy by mapping the financial transaction manipulation and optional mailbox-compromise branch while explicitly avoiding unsupported techniques. Facilitators should use the mapping as a discussion aid, not as a substitute for evidence-led investigation.

End-state for participants

Participants should leave with clearer decision rights, stronger confidence in out-of-band verification, a practical combined cyber/fraud response model, and specific improvement actions for payment controls, mailbox/identity monitoring, evidence preservation, and crisis communications.